

Cybersecurity

Risk Management and Threat Modeling

Lesson 22.2



Learning Objectives

By the end of today's lesson, you'll be able to:

- 1 Identify threat agents, possible attacks, and exploitable vulnerabilities relevant to a given asset.
- 2 Prioritize risks based on likelihood and impact potential.
- 3 Choose and justify controls for a given risk.

Today's lesson will introduce risk management and threat modeling as methods for identifying, anticipating, budgeting, and planning for when risks occur.

These tools will allow us to:

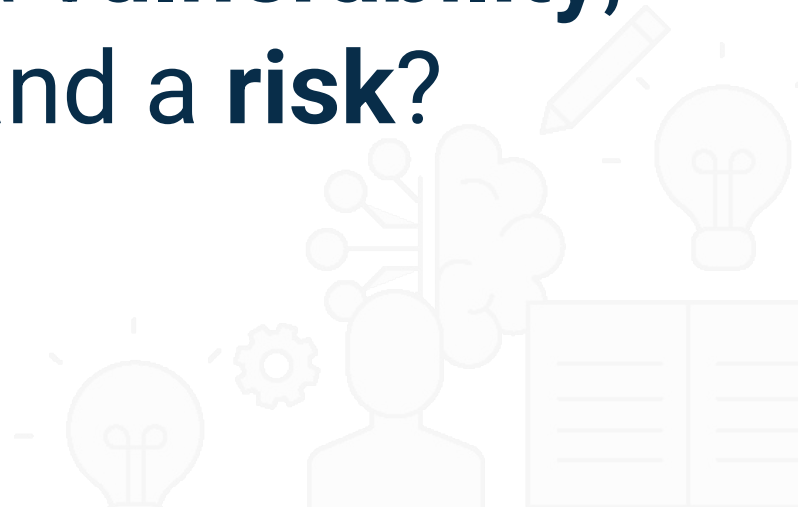
-  **Enumerate** possible risks, threats, and vulnerabilities to a company.
-  **Identify** the most likely and most serious risks.
-  **Evaluate** the impact the occurrence of a serious risk may have.
-  **Develop** strategies for monitoring and mitigating risks.

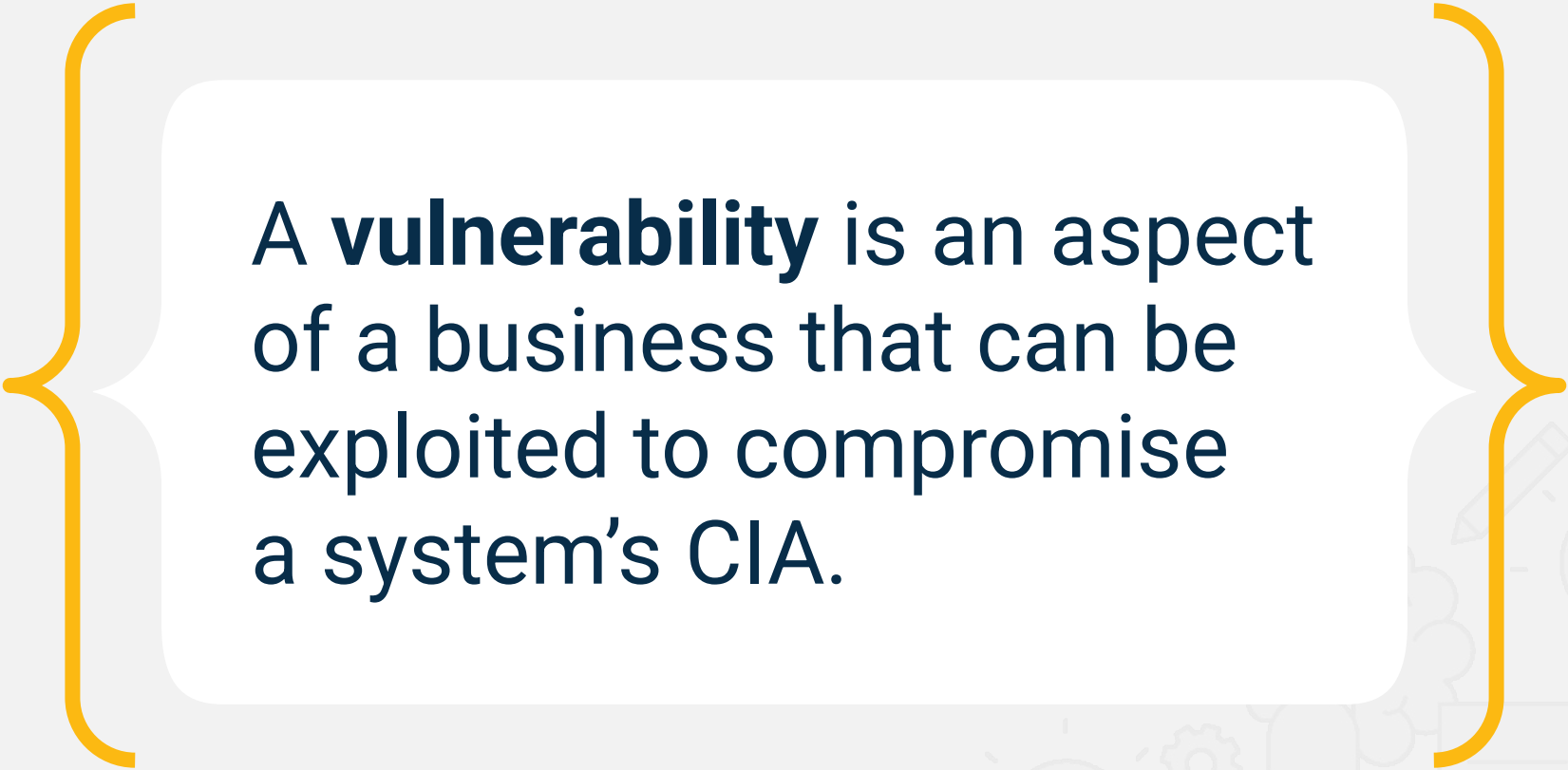


Threat Modeling and **Risk Management**



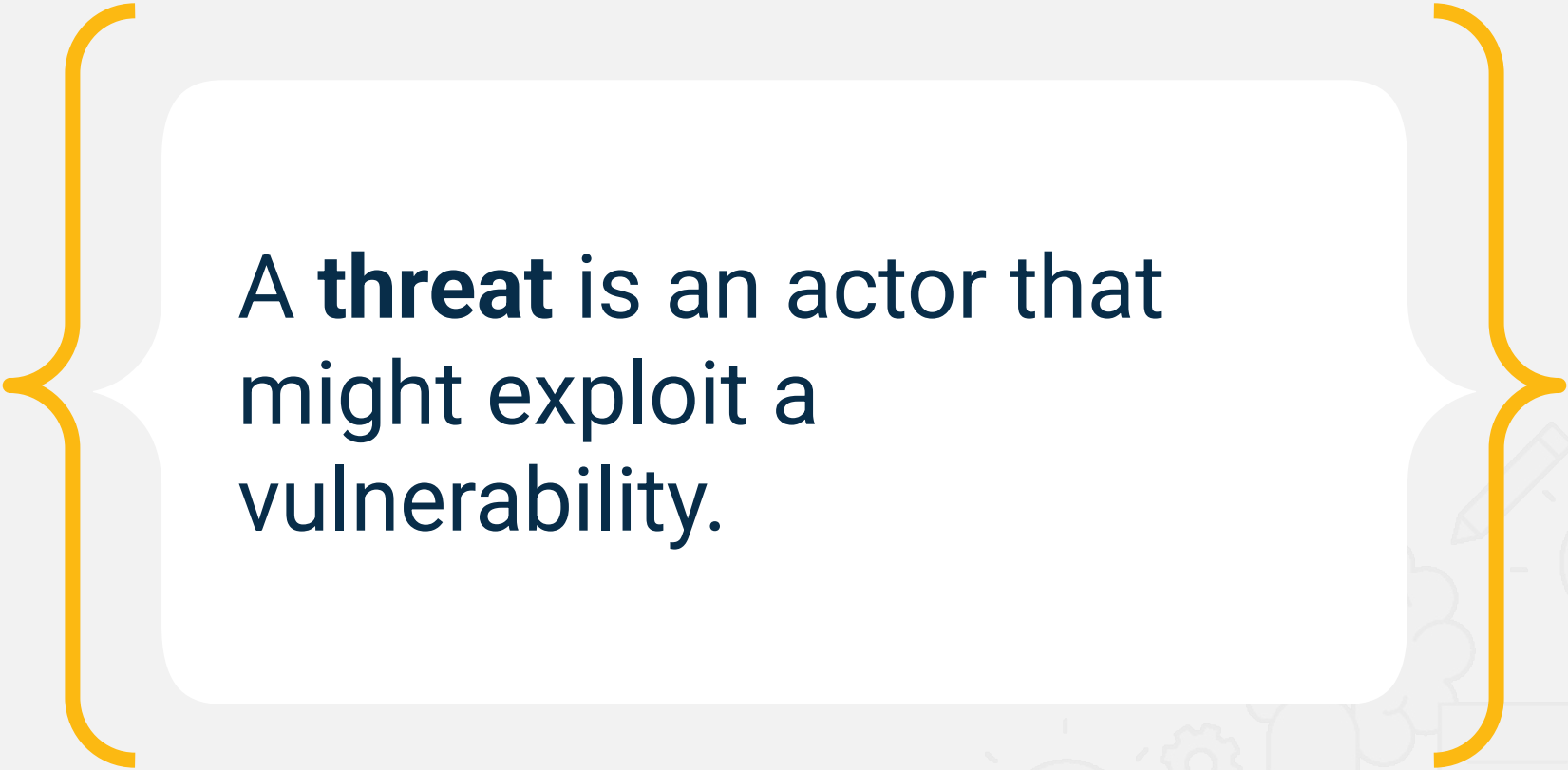
What's the difference
between a **vulnerability**,
a **threat**, and a **risk**?





A **vulnerability** is an aspect of a business that can be exploited to compromise a system's CIA.





A **threat** is an actor that might exploit a vulnerability.



A **risk** is the possibility of losing something valuable.

Risk Management and Threat Modeling

Risk Analysis	Understanding the risks faced by an organization, which are most severe, and which are most likely.
Risk Management	Using the results of risk analysis to create a plan for preventing likely risks.
Threat Modeling	Determining which attacks an organization is most likely to experience, who is most likely to launch them, and what actions can be taken to prevent them.



What is a business's
primary objective?





A business's primary
objective is to
maximise profits.



Risk Management and Threat Modeling



Risk analysis, risk management, and threat modeling directly contribute to business profit.



Risk analysis helps a business understand how much it will need to spend if a given security break happens.



When possible, risks are measured quantitatively in financial figures, which businesses use to prioritize threats.



Threat modeling results are shared upward to the executives who make the major business decisions.

Risk Management and Threat Modeling

These practices directly relate to a business's pursuit of profit:

Risk analysis is important because it quantifies how much a business needs to spend if a given security breaks happens.

Therefore, the business can plan for setbacks before they occur.



Threat modeling is a key step to risk management because a risk is essentially a price the business pays if the threat happens.

Therefore, it can prioritize the most expensive risks.

Threat Modeling Methodology: PASTA

PASTA focuses on aligning considerations of business objectives with technical requirements.



Process for **Attack Simulation** and **Threat Analysis**

Threat Modeling Methodology: STRIDE

STRIDE focuses on identifying what can fail in the system being modeled.

Spoofing

Tampering

Repudiation

Information disclosure

DoS (Denial of Service)

Elevation of privilege



Threat Modeling Methodology: OWASP

OWASP focuses on identifying possible threats, prioritizing risks, and planning mitigation strategies. It is mainly used with web and desktop applications.



Open
Web
Application
Security
Project

OWASP

The OWASP threat modeling process consists of six steps:

01

Determine assessment scope.

02

Identify threat agents.

03

Identify potential attacks.

04

Identify exploitable vulnerabilities.

05

Prioritize identified risks.

06

Mitigate risks.

Step 1: Determine Assessment Scope

List the assets under consideration, determine their value, and define objectives for your threat modeling assessment.

Businesses can't effectively evaluate everything at once, so they adjust their scope to focus on a specific category of risk.

Example

Performing a risk analysis to assess the weakness of a network infrastructure. Within this scope, we are not concerned with application security.

Scoping begins with asset inventory, the process of identifying and assigning asset value to all of an organization's assets.

Example

The asset value of a web application could be measured by the revenue or profit it generates.

Step 2: Identify Threat Agents

Determine which attackers would be interested in the relevant assets.

Threat agents include a person or group that can produce a threat, whether or not that person or group is malicious. Threats agents include:

- Advanced persistent threats (APTs)
- Script kiddies
- Employees opening phishing emails
- Incompetent users breaking configurations on company computers

Previously, we've addressed unwitting threat agents, like employees opening phishing emails.



The diagram consists of two chevron-shaped boxes. The left box is light blue and points to the left, containing the text 'Previous lesson'. The right box is yellow and points to the right, containing the text 'This lesson'. A vertical line with a dot at the top connects the text above to the blue box. Another vertical line with a dot at the bottom connects the text below to the yellow box.

Previous lesson

This lesson

Today, we'll focus on malicious threat agents.

Step 3: Identify Potential Attacks

Identify the attacks each agent is likely to perform.

Different attackers use different modes of attacks. Different attacks mean different risks and considerations.

Example

Script kiddies will have different goals than disgruntled employees.

We can identify a potential attack by considering the threat agent's motivation, skill level, and amount of funding.

Example

If a client's web application is taken offline by a DoS attack, the severity of the risk depends on which threat agent is responsible.

- Script kiddies might DoS a server simply to cause trouble.
- An APT might DoS a server as a smokescreen to steal valuable data.

Step 4: Identify Exploitable Vulnerabilities

Identify the most vulnerable points in a system, how the agent will deliver the attack, and where an attack is most likely to occur.

Once we determine who might attack and what methods they might use, we determine where exactly in the system they will likely direct their attacks and what the risk will be if they do.

Example

If a network has only one database that stores everything, the entire company will lose access to all data if it is compromised.

An attacker seeking to DoS the company's network can exploit this database to achieve their goal.



Activity

Threat modeling: Steps 1–4

In this activity, you'll learn more about GeldCorp's business operations and assets before applying Steps 1–4 of the OWASP process.

Suggested Time
25 minutes





Time's Up!
Let's review



Questions?

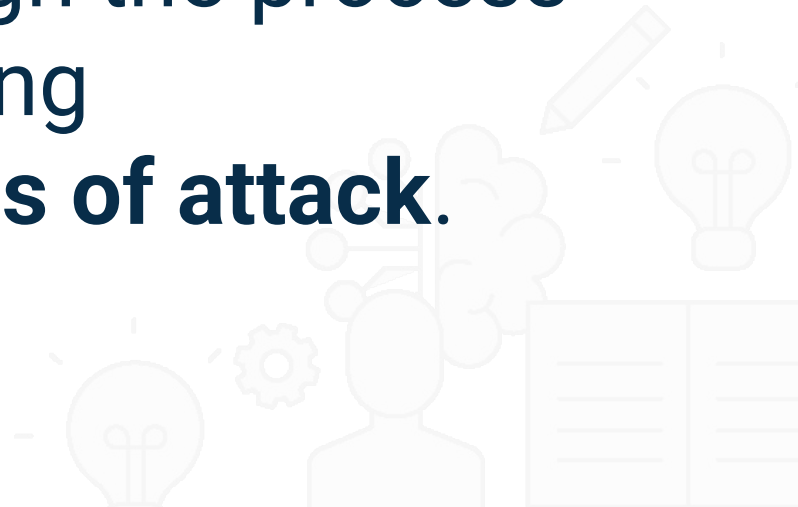




Risk **Analysis**



In this section, we will
focus on risk analysis and
walk through the process
of prioritizing
possibilities of attack.



Risk Management Terms

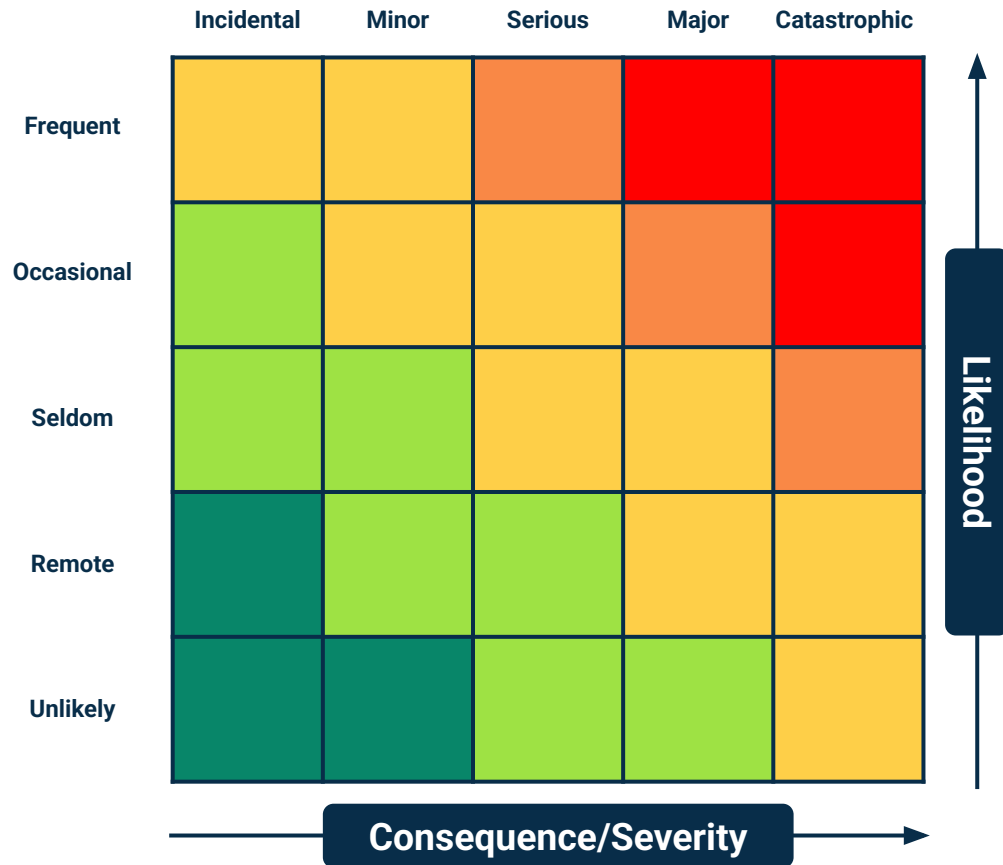
- Risk = threat x vulnerability
- Vulnerability is a weakness or misconfiguration in a system.
- A threat is any potential danger that is associated with the exploitation of a vulnerability.
- Exposure is an instance of being exposed to losses.
- Control, or countermeasure, is put in place to mitigate (reduce) the potential risk.

Relationship Cybersecurity Ecosystem



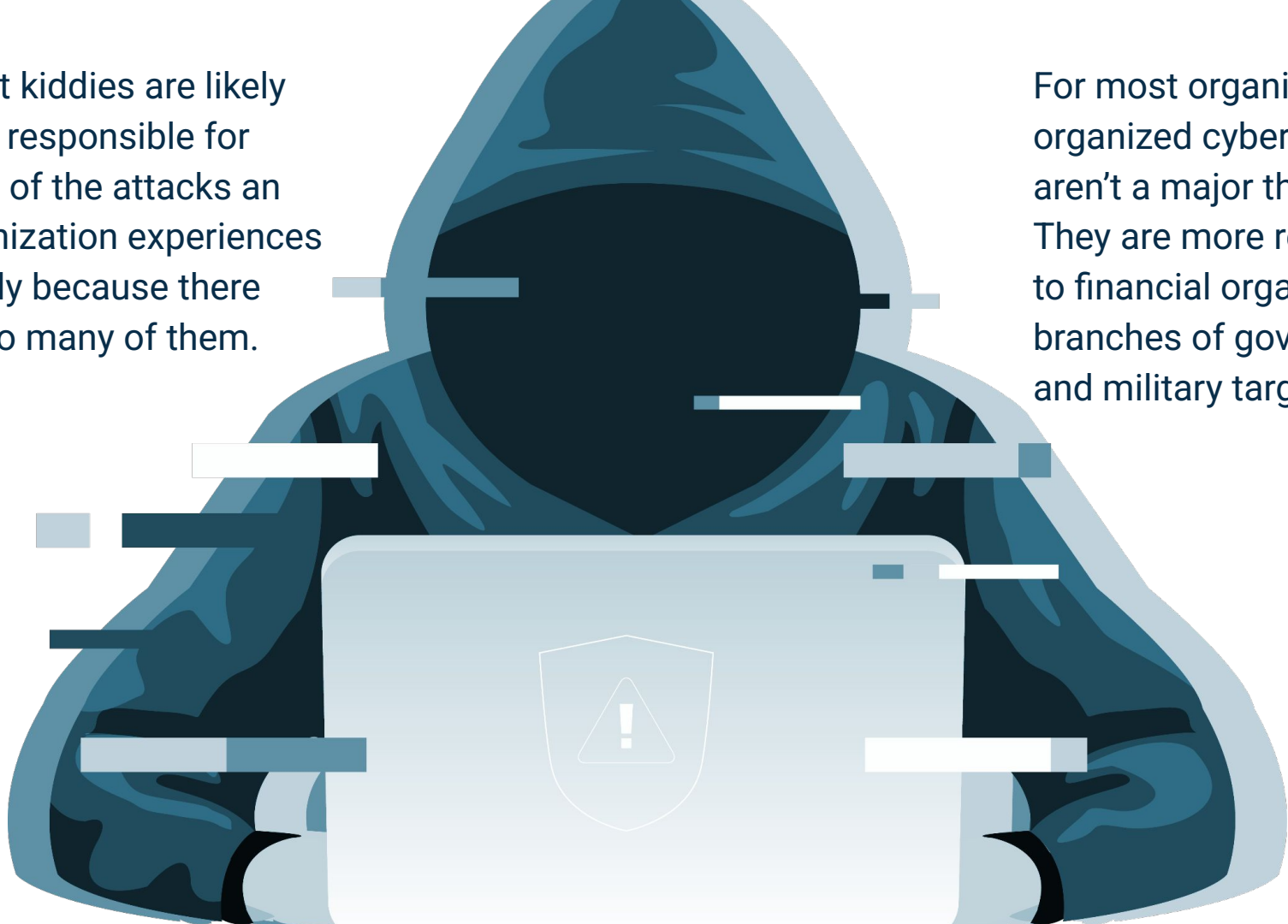
Risk Analysis

Risk analysis is the process of prioritizing threats identified in Steps 1–4 based on their potential impact and likelihood. **Some threats are more likely than others.**



Script kiddies are likely to be responsible for most of the attacks an organization experiences simply because there are so many of them.

For most organizations, organized cyber criminals aren't a major threat. They are more relevant to financial organizations, branches of government, and military targets.



Risk Analysis: Scenario

You've identified more than 10 potential attacks that GeldCorp should consider.

- All can be mitigated, but each fix costs around \$2,500.
- GeldCorp's security department only has \$10,000 budgeted for the project.
- You must advise which four fixes should be prioritized.



Risk Analysis: Scenario

Before completing this activity, we'll learn about:

- 1 Qualitative vs. quantitative risk analysis.
- 2 Likelihood, impact, and loss expectancies.
- 3 Risk factor and heat maps.

Qualitative vs. Quantitative Risk Analysis

Qualitative Analysis

- Evaluates risk based on intangible, unmeasurable factors.
- Used when decisions do not require cost-benefit analysis.

Quantitative Analysis

Evaluates each risk based on its measured likelihood and impact.

- **Likelihood:** The probability that an event will take place.
- **Impact:** The measure of damage if a risk takes place.

Qualitative vs. Quantitative Risk Analysis

Characteristic	Qualitative	Quantitative
Requires complex functions	No 	Yes 
Uses cost-benefit analysis	No 	Yes 
Results in specific values	No 	Yes 
Requires guesswork	Yes 	No 
Requires automation	No 	Yes 
Involves a high volume of information	No 	Yes 
Objective (based on facts)	No 	Yes 
Uses opinion	Yes 	No 
Requires significant time and effort	No 	Yes 
Offers useful and meaningful results	Yes 	Yes 

Qualitative Risk Analysis

In some situations, likelihood and impact cannot be accurately measured.

Example 1

It's impossible to calculate the precise probability that some hacker, somewhere in the world, will attack your servers within the next year.

Example 2

It's impossible to know the precise impact of a breach. The cost of an attack will depend on its length, which is impossible to determine ahead of time.



Qualitative risk analysis is used when a complex evaluation of cost vs. benefit is unnecessary.



Qualitative Risk Analysis

Example:

A company is deciding between an inexpensive VPN service that logs traffic on its servers for internal use and a more expensive service that does not keep any logs.



A **bakery** can use qualitative analysis to decide on an inexpensive VPN since it shouldn't matter much if it is logging non-confidential information.



A **government defense** or **financial organization** can use qualitative analysis to decide on a more expensive service since it knows it needs to keep its data confidential.

Quantitative Risk Analysis

However, there are circumstances where intuitive analysis is insufficient.

Example 1

The security department wants to invest in protecting the organization's infrastructure.

To secure money from the finance department, they must justify their ask. They will present a quantitative risk analysis to demonstrate that the cost of not investing is much greater than the budget they're requesting

Example 2

The executive team must decide whether to migrate to a new cloud provider as part of negotiations with a potential partner.

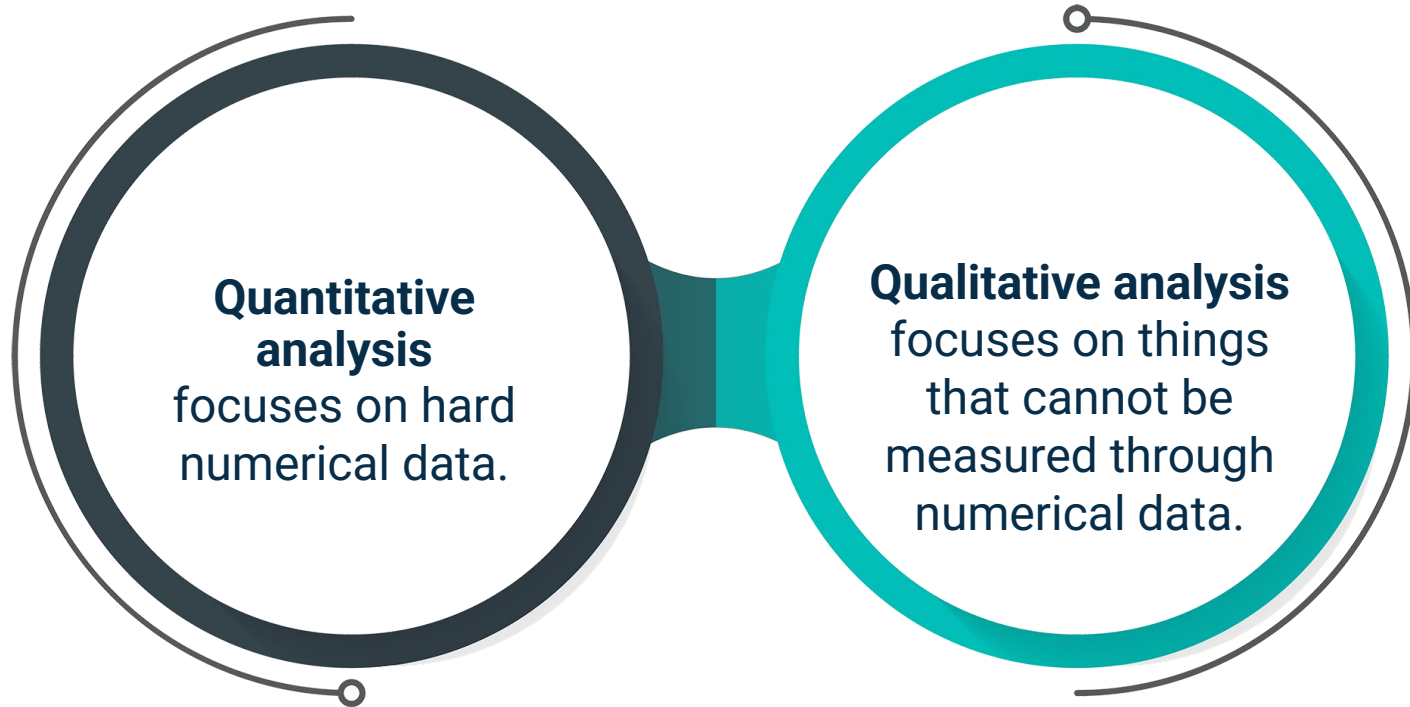
To make this decision, they need an accurate assessment of potential losses due to downtime, retraining, risk of data corruption during migration, and other issues.



What's the
main difference
between qualitative and
quantitative analysis?



Qualitative vs. Quantitative Risk Analysis



Asset Value and Exposure Factor

To perform quantitative risk analysis, analysts start by calculating how much it will cost if an asset is breached.



Analysts first quantify **asset value** and **exposure factor**.



Asset value is how much money an asset is worth in currency.



Exposure factor is how much of an asset will be affected in the breach.



In other words, whether an attack will result in **partial and temporary** or **complete and permanent** destruction of an asset.

Determining Exposure Factor

Exposure factor is always somewhat subjective. We apply a numerical value for the level of damage an exploited risk would produce.

1.0

Attack would **completely eliminate** an asset.

0.75

Attack would **mostly eliminate** an asset.

0.5

Attack would **half eliminate** an asset.

0.25

Attack would **partially eliminate** an asset.

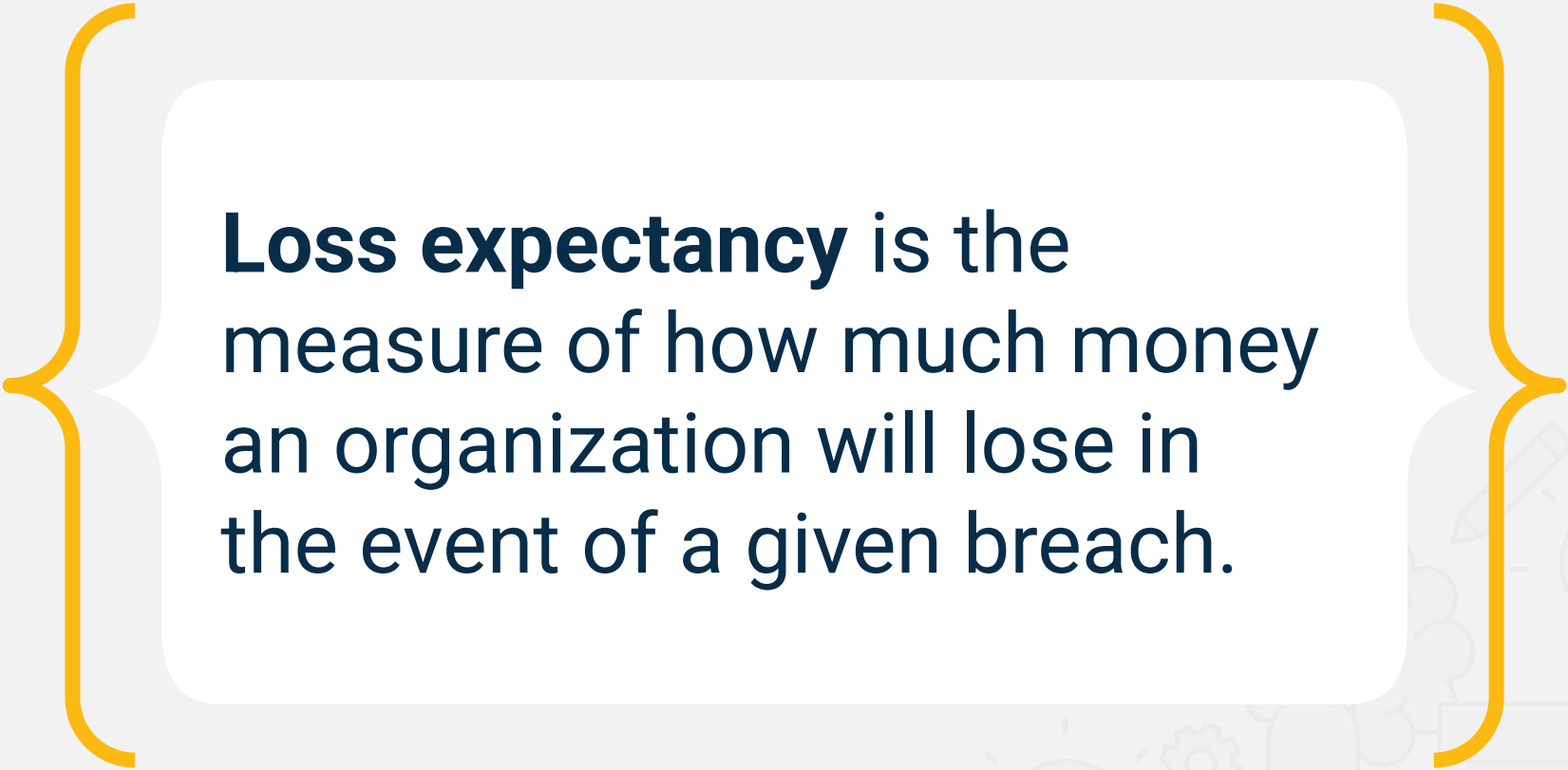


A mail server that's reduced to 0% functionality during a power outage has an exposure factor of what?

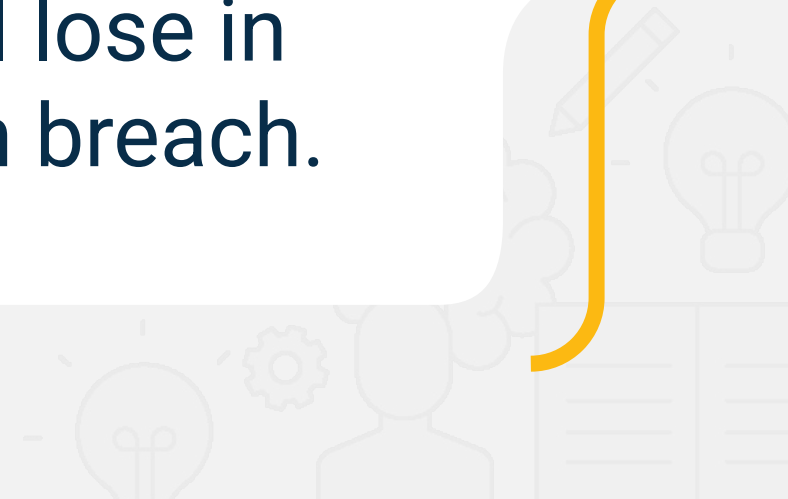


Exposure Factor of 1





Loss expectancy is the measure of how much money an organization will lose in the event of a given breach.



Loss Expectancy

Single Loss Expectancy (SLE)

Estimated cost of the risk occurring on a given asset.

$$\text{SLE} = \text{AV} \times \text{EF}$$

AV = Asset value
EF = Exposure factor

Annual Rate of Occurrence (ARO)

Estimated number of times the risk is likely to occur in a given year.

$$\text{ARO} = X / 1 \text{ years}$$

X = number of occurrences

Annual Loss Expectancy (ALE)

Estimated cost of a risk occurring in a given year.

$$\text{ALE} = \text{SLE} \times \text{ARO}$$



With an asset value of \$10,000 and an exposure factor of 0.5, what is the single loss expectancy?



$$\mathbf{SLE = AV \times EF}$$

$$10,000 \times 0.5 = 5,000$$



Loss Expectancy

Categories of loss expectancy refer to the degree of a breach's impact.

Marginal

The organization has the resources to respond to the breach immediately, without affecting day-to-day operations or revenue.

Notable

The organization has the resources to respond to the breach, but may not be able to do so immediately. May experience interruptions to operations.

Severe

The organization experiences serious interruptions to operations, and doesn't have the monetary and/or personnel resources to respond effectively. May have to defer revenue, delay project timelines, reassign employees, or hire consultants to fix the issue.

Catastrophic

The organization suffers severe, lasting damage to its reputation and/or infrastructure. The future of the business is threatened by reputational damage, bankruptcy, being found in contempt of federal regulations, or other issues.



In the next demonstration, we'll see data presented in a spreadsheet and visual formats known as **risk matrices** and **heat maps**.

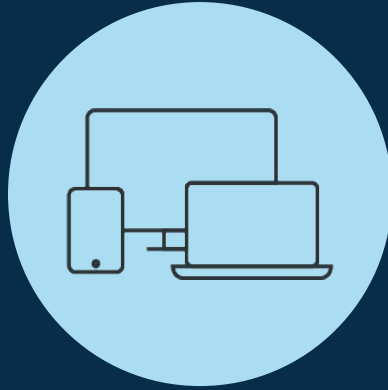
Risk Matrices and Heat Maps

During a risk assessment, we visualize risks to get a holistic view of risks affecting an organization.

A **risk matrix** is used to compare how many of the risks facing an organization are mild and how many are severe.

A **heat map** is a visual representation of the probability and likelihood of risks. Organizations can use heat maps to make strategic decisions about how to protect the company.

		10 Low	20 Medium	30 High	40 Very High
10	Low	1	0	0	0
20	Medium	2	0	0	0
30	High	2	1	0	1
40	Very High	1	0	0	1



Instructor Demonstration

The risk spreadsheet



Break
15 mins



Activity

Threat modeling Step 5: risk analysis

In this activity, you will complete a spreadsheet and generate a risk matrix and heat map for GeldCorp.

Suggested Time
30 minutes



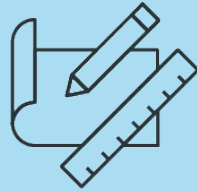


Time's Up!
Let's review



Questions?

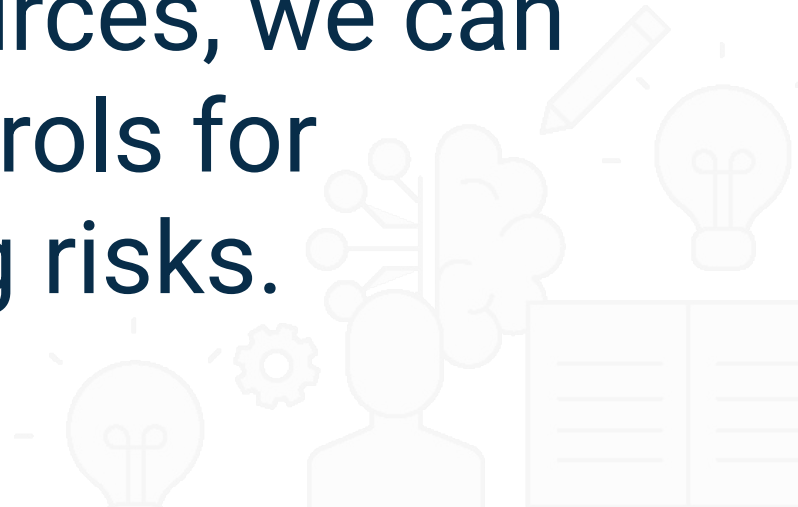




Mitigating **Risks**



Now that we're able to determine which threats are worth our attention and resources, we can craft controls for mitigating risks.



Deciding on Security Controls

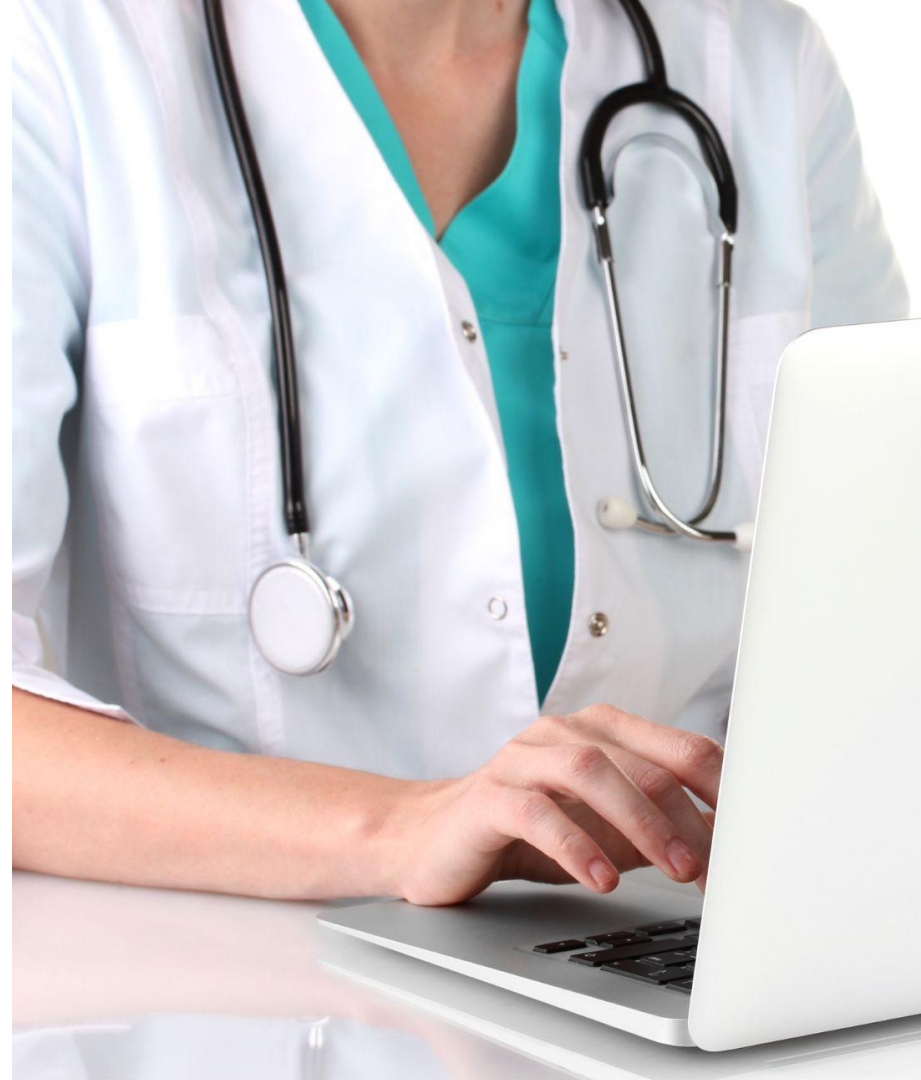
Answer the following questions when determining an appropriate control:

- 1 **Required control type:** Should the control be physical, administrative, or technical?
- 2 **Required control strength:** How strong does the control need to be?
- 3 **Implementation cost:** How much does the control cost compared to the benefit provided?
- 4 **Implementation time:** How long will the control take to implement?

Risk Mitigation: Example

LifeNotes is a new medical records company that makes it easy for doctors from different hospitals to share medical records.

- When transferring a patient to another hospital or physician, doctors can use the application to share the patient's medical history, lab results, and medication schedules.
- LifeNotes also ensures that doctors can only see records for their own patients.
- However, a client recently reported that they were able to load records for patients they were not assigned to.
- This violates regulatory standards protecting patients' medical information and it must be resolved immediately.



Risk Mitigation: Example

What security controls should we suggest to LifeNotes?

- 1 Required control type
- 2 Required control strength
- 3 Control decisions
- 4 Implementation cost
- 5 Implementation time



Risk Mitigation: Example

What security controls should we suggest to LifeNotes?

- 1 Required control type
- 2 Required control strength
- 3 Control decisions
- 4 Implementation cost
- 5 Implementation time

Since this problem must be fixed immediately, LifeNotes must implement a corrective control. It should also implement protective controls to prevent the issue from recurring. This can be accomplished with administrative to technical controls.

Risk Mitigation: Example

What security controls should we suggest to LifeNotes?

- 1 Required control type
- 2 Required control strength
- 3 Control decisions
- 4 Implementation cost
- 5 Implementation time

The corrective control must completely resolve the issue since the bug means that LifeNotes is in violation of the law. The protective control(s) must completely prevent this issue from recurring, for the same reason.

Risk Mitigation: Example

What security controls should we suggest to LifeNotes?

- 1 Required control type
- 2 Required control strength
- 3 Control decisions
- 4 Implementation cost
- 5 Implementation time

The corrective control must completely resolve the issue since the bug means LifeNotes is in violation of the law.

- **Corrective control:** Redeploy the older version of the application, which did not have this issue.
- **Administrative control:** Change the way doctors and hospitals communicate data, requiring clients to change their processes and LifeNotes to change how its application works.
- **Technical control:** Implement two-factor authentication, requiring an engineering team to implement a new feature and doctors to learn a new workflow.

Risk Mitigation: Example

What security controls should we suggest to LifeNotes?

- 1 Required control type
- 2 Required control strength
- 3 Control decisions
- 4 **Implementation cost**
- 5 Implementation time

LifeNotes can implement the following example controls:

- **Low cost:** Roll back to an older version of the application.
- **High cost:** Change the way doctors and hospitals communicate data, requiring clients to change their processes and LifeNotes to change how its application works.
- **Medium cost:** Implement two-factor authentication, requiring an engineering team to implement a new feature and doctors to learn a new workflow.

Risk Mitigation: Example

What security controls should we suggest to LifeNotes?

- 1 Required control type
- 2 Required control strength
- 3 Control decisions
- 4 Implementation cost
- 5 Implementation time

Rolling back to an older version of the application should take less than a day. Administrative controls would take months to implement. Implementing two-factor authentication would likely take approximately one quarter (three months).



Activity

Threat modeling Step 6: risk mitigation

In this activity, you will conceptualize a risk mitigation plan.

Suggested Time

15 minutes





Time's Up!
Let's review



Questions?





Thank You